Technical Bluebook

企业级人工智能安全技术蓝皮书

统一 AI 安全控制面、解耦安全与评测框架

Scope. Unified AI Security Control Plane • Decoupled Safety • Evaluation Framework

Purpose. Establish a rigorous, enterprise-grade technical blueprint for controllable, auditable, and evolvable AI security.

Author(s)	王云浩等
Organization	数字信任 / 天木 / AI 安全研究

Version	v1.0-草案
Date	April 23, 2026
Classification	内部草案
Keywords	AI 安全; 统一控制面; 解耦安全; 运行时强制; 评测框架

全书以 Unified AI Security Control Plane 为总对象，以 Decoupled Safety 为系统原理翼，以 Evaluation Framework 为证据与治理引擎翼；三者闭环，支撑可部署、可审计、可发布辩护的企业级 AI 安全。推荐使用 XeLaTeX 编译。

Contents

1 统一 AI 安全控制面：问题陈述与系统边界 . . . 2
1.1 战略背景与企业级转型 . . . 2
1.2 系统边界与责任划分 . . . 2
1.3 控制面必要性：义务—断裂点—总对象 . . . 3
1.4 控制面作为唯一总对象：否定性论证与四元闭合 . . . 3
1.5 阅读约定与主张口径（摘要） . . . 3
1.6 资产、对手模型与运行假设 . . . 3
1.7 安全目标与权衡 . . . 4

2 解耦安全：概念基础与安全模型 . . . 6
2.1 引论：对齐与系统安全的间隙 . . . 6
2.2 三类基础失效及其设计含义 . . . 6
2.3 最小对象模型（与第 3–5 章接口） . . . 7
2.4 典型失效模式 . . . 8
2.5 有界主张与本书安全契约（bounded claim） . . . 8

3 参考架构与解耦安全内核 . . . 9
3.1 分层参考架构 . . . 9
3.2 数据面、控制面与证据面 . . . 9
3.3 Decoupled Safety Kernel 接口 . . . 9

4 运行时强制与策略编排 . . . 11
4.1 风险自适应控制闭环 . . . 11
4.2 策略决策生命周期 . . . 11
4.3 检索安全（RAG） . . . 12
4.4 工具调用控制 . . . 12
4.5 两阶段 Fail-Safe 服务协议 . . . 12
4.5.1 触发接口（三类信号） . . . 12
4.5.2 降级动作空间（受控四象） . . . 12
4.5.3 服务不变量（示例 S1） . . . 12
4.5.4 异构恢复层级 . . . 12

5 评测框架：安全、效用与系统保证 . . . 14
5.1 评测问题与证据映射（RQ-first） . . . 14
5.2 语义、基准与验收契约 . . . 14
5.3 指标分层 . . . 14
5.4 共享基础设施下的多轨评测 . . . 15
5.4.1 Track A 与 Track B 纪律（禁止混读） . . . 15

5.5 协议：离线、在线、回归与发布 15
5.6 最小可部署证据包（Minimum Deployable Evidence Pack） 16

6 治理、部署与研究路线 17
6.1 主张口径与非目标（Claim discipline） 17
6.2 前提条件与退化态（Preconditions & degradation regimes） 17
6.3 证据图谱与发布治理 18
6.4 组织运作模型 18
6.5 分阶段部署路线 18
6.6 研究路线 18

A 地域化与多语言评测 20

B 术语与角色边界 21

Abstract. 本蓝皮书采用一主两翼结构：**总对象**为 Unified AI Security Control Plane——在统一边界内同时承载安全判断、运行时强制与可复核证据；**系统原理翼**为 Decoupled Safety——策略优先于模型偏好，以可组合接口将义务外置并可测；**证据与治理引擎翼**为 Evaluation Framework——以基准宪章、验收契约、多轨纪律与最小证据包，将测量、回归与发布闸绑为同一条证据链。核心论点是：企业级 AI 安全属于控制面问题；保证须由外置强制与可度量证据共同提供，而非仅依赖静态对齐或零散护栏。本书给出的是有界、可部署主张：明示前提、非目标与退化态，而非自然语言意义上的全局安全证明。

Executive Summary

- **一主两翼**。**主**——Unified AI Security Control Plane：统一边界内的判断、强制与证据。**翼 A**——Decoupled Safety：外置、策略优先、可协议化降级。**翼 B**——Evaluation Framework：契约、多轨纪律、最小证据包与发布闸。
- **背景**。生产 AI 已复合化（编排、RAG、工具、记忆、多轮智能体）；风险覆盖 CIA 与治理，远超出有害输出。
- **问题**。能力扩张快于一致执行、可追溯、可发布级保证；单模型对齐与松耦合护栏不足以闭合系统攻击面。
- **边界**。本书不提供全局自然语言安全证明；提供在明示前提与 fail-safe 退化下的可部署、可测量、可撤回有界保证（第 6 章展开）。
- **交付物**。威胁模型与目标；分层架构与 Decoupled Safety Kernel 接口；含 fail-safe 协议的运行时与 RAG/工具模式；含 RQ 映射、Track A/B 纪律与最小证据包的评测框架；证据图谱与分阶段路线；附录收地域化评测与角色边界。

Chapter 1

统一 AI 安全控制面：问题陈述与系统边界

Chapter Objective

本章只完成一件事：论证为什么必须是控制面——用可反驳的失败命题、义务—断裂链、否定性对比与四元闭合，把边界、威胁表与目标收紧为总对象 Unified AI Security Control Plane；阅读口径与第 6 章 claim discipline 对齐。

Deliverables

- 失败命题与问题陈述；义务—控制点—断裂与四元闭合。
- 否定性论证（非模型平台、非功能集合）；边界与威胁表、CIA+ 目标。
- 主张口径摘要（非目标、有界保证；详见第 6 章）。

1.1 战略背景与企业级转型

主线： Unified AI Security Control Plane。企业级 AI 已表现为分布式系统：网关、路由、向量与文档索引、工作流、插件、人机环节并存。风险是系统性的而非「坏一句输出」：提示注入迁移信任边界；投毒与隐指令经检索进入上下文；工具把语言映射为副作用；编排状态在轮次间累积；若日志与决策不可关联，则问责链断裂。传统应用安全或内容安全若仅作外挂模块，各自优化局部 KPI，无法给出同一套可版本化的强制语义与证据编目——这正是控制面要接管的真空。

1.2 系统边界与责任划分

主线： Unified AI Security Control Plane。本蓝皮书固定两类责任：（i）安全判断——策略解释、风险评分、允许/拒绝/改写、可解释载荷与面向治理的证据；（ii）执行平台——网络、扩缩容、编排 SLA、算力与放置。Unified AI Security Control Plane 的语义锚点是策略与证据，不是替执行平台背锅，也不是把安全降格为「换更大模型」。凡进入提示边界的外部物（文档、检索块、工具契约、API 响应）均视为攻击面组成部分，须与判断、强制与证据同一编目。

Problem Statement

可反驳的失败命题如下：在保持同一发布语义（对谁承担何种义务、何种数据不得出境、何种工具不得越权）的前提下，若仅通过更强单模型或更多离线对齐与红队分数，而不引入横跨输入—检索—工具—编排—日志的统一控制与证据面，则无法在复合系统中持续满足「策略—线上行为—放行材料」三者一致。因此中心问题不是「模型是否更对齐」，而是：在动态语境、外部检索、工具副作用、记忆与多租户下，**判断（judgment）、执行（execution）、证据（evidence）、放行（release）**是否能在同一版本面与关联 *ID* 下闭合。若四者不同框，则必出现至少一类系统级断

裂：线上生效策略与签字放行依据不一致；或审计无法回答「当时依据哪版策略、哪条检索、哪次工具调用」；或回归与生产使用不同事件定义。结论：必须引入 Unified AI Security Control Plane 作为总对象——统一语义、确定性强制挂点与可发布级证据链（与第 5–6 章同构）。

1.3 控制面必要性：义务—断裂点—总对象

主线：Unified AI Security Control Plane。将义务映射到控制点，再追问若缺少总对象会在何处断裂。（1）**租户与数据义务**——同一权重无法编码多租户差异；义务必须落在可版本 policy 与可审计绑定上，否则升级模型即静默改写「有效策略」。（2）**检索与工具义务**——义务附着在语料切片与工具能力矩阵上；无统一事件面则无法在放行中复现「允许了哪一段外部文本、哪一次调用」。（3）**放行义务**——发布材料必须引用与线上一致的策略包、模型路由与检测器版本；若证据 schema 不统一，法务与对内问责无法复用同一对象。**链接四元：**判断输出必须可执行为强制动作；强制必须写证据；证据必须可进入放行与回归；放行约束反过来收紧评测与线上策略——四者共享同一 Unified AI Security Control Plane 编目，否则任一环都会沦为局部优化或与事实脱节。

1.4 控制面作为唯一总对象：否定性论证与四元闭合

主线：Unified AI Security Control Plane。

（一）**为什么不是「模型安全平台」**。模型平台优化的主语是生成与 *serving*：吞吐、延迟、路由到哪个 checkpoint。租户义务、工具副作用、检索血缘、发布闸与签批制品不是同一生命周期一等公民；把安全等同于「更好的模型」会使「有效策略」随权重漂移而无回归对象。模型平台可成为执行子系统，但不能替代控制面承担四元闭合。

（二）**为什么不是「安全功能集合」**。检测器、脱敏、WAF、日志各自最优，往往导致**全局次优**：重复拦截、绕过路径、口径不一致的日志、无法合并的 KPI。更致命的是缺乏统一事件类型与证据关联 *ID*：无法回答「同一次请求在网关通过、在工具层被拒、最终对用户展示了什么」的单一叙事，放行与事故复盘分裂。

（三）**为什么只有 control plane 能统一 judgment / execution / evidence / release**。四元必须共享：**同一策略版本**约束在线求值与离线聚合；**同一证据 schema** 贯穿运行时日志、影子对比与签批附件；**同一 release 对象**（策略包 + 模型路由 + 检测器/规则包 + 必要遥测切片）支持差分重跑与责任切片。只有控制面提供这一版本面与编目；模型平台与功能集合均不具备把四元压成单一可辩护对象的构造能力。

1.5 阅读约定与主张口径（摘要）

主线：Unified AI Security Control Plane / Evaluation Framework。本书承诺的是可部署、可测量、可撤回的企业安全契约：在明示前提（见第 6 章）下，通过 Decoupled Safety 与 Evaluation Framework 提供有界保证。**非目标**包括：不对任意开放自然语言任务给出全局安全证明；不将单次离线红队分数等同于生产放行；不将不同评测轨（尤其「可部署结论轨」与「机制上界压力轨」）混读为单一总分。完整非目标、前提与退化态见第 6 章。

1.6 资产、对手模型与运行假设

主线：Unified AI Security Control Plane / Evaluation Framework。受保护资产包括：用户与企业数据的机密性，提示与检索内容的完整性，工具侧效果与参数完整性与不可否认性，服务

在 SLA 内的可用性，以及审计记录的完整性。考虑的对手包括：构造对抗性提示；经检索信道投毒或泄露；滥用或串联工具调用；操纵会话与工作流状态；滥用运营面（如文档中的隐匿指令）。内部威胁主要通过职责分离、证据不可篡改与工具最小权限来缓解——而非仅靠模型对齐。

运行假设包括：策略可以机器可核验的片段表述；在网关、检索、推理、工具与日志层存在强制挂点；部分残余风险通过验收契约明示接受；非确定性须由统计检验计划与在线监控界定，而不能被笼统忽略。

Threat Model

Threat Surface	Adversary Goal	Attack Pattern	Potential Impact	Control Point
提示交互面	策略绕过或经指令的数据渗出	越狱、分隔符攻击、间接提示注入	策略失效、数据泄露、特权滥用	输入治理、规范化、指令边界
检索路径	语料操纵 / 敏感信息暴露	投毒、冲突来源、文中注入指令	错误或有害答案、泄漏、合规失败	检索安全、血缘、分段、引用绑定
工具调用层	特权提升	工具链攻击、伪造参数、模糊审批	数据损毁、财务或运营影响、横向移动	工具策略、审批、沙箱、限速
模型执行层	善意意图下的不安全生成	对齐尖峰、事实幻觉	有害内容、不可靠自动化	输出治理、事实锚定(grounding)约束、校准弃权
运行时编排	控制面不一致	跨轮状态操纵、陈旧策略绑定	静默策略漂移、审计断裂	策略引擎版本化、原子化决策日志

1.7 安全目标与权衡

主线： Unified AI Security Control Plane / Evaluation Framework。下列目标在系统层面须一并满足；每条均附若不纳入控制面则必然失灵的判据，以钉死总对象必要性。

Security Objectives

- **机密性（Confidentiality）**。敏感数据不得经提示、检索、日志或工具输出逾越策略信任边界。**若不在控制面：**各模块独立脱敏，无法证明「同一次跨检索—工具链」未泄漏切片级义务。
- **完整性（Integrity）**。提示、检索片段、工具参数与侧效果在威胁假设内可检。**若不在控制面：**放行与线上求值使用不同字段定义，完整性主张不可辩护。
- **可用性（Availability）**。控制在 SLA 内可服务；降级可度量。**若不在控制面：**安全与平台各报各的延迟，无法对「带安全时的 p99」签单一合同。
- **可控性（Controllability）**。高风险行为由显式运行时策略约束。**若不在控制面：**「模型习性」无法版本化，亦无法进入回归闸。

- **可审计性（Auditability）**。策略相关决策产生可回放结构化证据。**若不在控制面：**审计与生产日志无法共享关联 ID，事故复盘止于猜测。
- **可组合性（Composability）**。控制在异构模型与栈上仍有效。**若不在控制面：**每次换模型即换一套隐式策略，组织无法积累可比较证据。
- **效用保持（Utility Preservation）**。无谓损害最小化；无谓拦截为缺陷指标。**若不在控制面：**局部模块各自优化拦截率，全局效用无人负责。

权衡。机密性/完整性与效用、可用性常冲突；审计深度与成本、时延冲突。此类张力必须在控制面内政策化（版本、阈值、例外与证据包），否则沦为各团队即兴谈判。Decoupled Safety（第 2 章）提供外置策略优先机制；Evaluation Framework（第 5 章）提供可测与可放行证据；二者均依赖本章确立的总对象边界。

Design Principle

解耦（支撑 judgment）. 策略与模型权重分离，使「当时依据哪条规则」可被引用与签字。

Design Principle

跨层强制（支撑 execution）. 从输入、检索、推理、工具到输出与编排日志的强制挂点处于同一事件与版本语义下。

Design Principle

证据先于信任（贯通 evidence 与 release）. 任何对外与对内保证须可指向测试、遥测或签批制品，并与放行对象同一版本面。

Key Takeaway

企业级 AI 安全的中心矛盾是四元是否闭合：判断、执行、证据与放行必须在 Unified AI Security Control Plane 的同一编目与版本面下可关联、可差分重跑；否则在复合系统下义务必然断裂——故总对象只能是控制面，而非模型平台或功能集合。

Chapter 2

解耦安全：概念基础与安全模型

Chapter Objective

本章只完成一件事：论证为什么必须是 *Decoupled Safety*——用对齐—系统间隙、三类基础失效（必要性）与对应设计含义、最小对象表、工程反例与有界主张，把外置策略优先压成可与第 3–5 章对接的契约语言。

Deliverables

- 引论：对齐与系统安全的间隙；非形式注记（计算/验证边界）。
- 三类失效—设计含义；定义与不变式；最小对象表（含 fail-safe 与带外适应对象）。
- 典型失效；有界主张（与第 1、6 章同构）。

2.1 引论：对齐与系统安全的间隙

主线：Decoupled Safety。监督微调与对齐可压低孤立补全的有害率，但不构成对「检索—工具—编排—多租户」系统的义务证明：同一权重无法同时编码互斥租户义务；工具副作用与检索血缘不在单轮损失里显式出现；离线「安全」评分与线上放行材料常缺同一对象 ID。将安全寄托于「更大模型再多想一步」在开放操纵压力下不可签订服务合同——必须外置可版本策略、可判定事件与可记录决策，并在冲突时进入协议化 fail-safe（第 4 章）。

Remark 2.1 (从不可判定性到实例契约（非形式注记）). 相关理论工作指出：在足够富表达的任务空间里，全局语义安全或理想化审查目标面临不可判定性与计算—验证张力。蓝皮书不承接形式定理证明义务，而取其工程推论：企业可交付的是实例级、带明示前提与资源边界的策略契约——对具体 **event** 求值、产出 **decision** 与 **evidence**，并对失败形态规定 **FailSafeObject** 所允许的退化。由此，Decoupled Safety 是必要性回应而非口号。

2.2 三类基础失效及其设计含义

主线：Decoupled Safety。以下每条均写清：**失效形态（必要性）→ 设计含义（必须外置什么）**。不主张用更复杂单次提示或更大模型单点消化。

（一）语义审查失效与计算—验证不对称。 **必要性：**在开放任务与富语境下，把「审查一切有害语义」作为全局在线目标不可执行或可执行性无界，与算力、时延及可测试性冲突。**设计含义：**将验证收缩到实例：对离散 **event**（输入块、检索单元、工具调用、候选输出）在版本化 **policy** 下做可重复求值，并由 **kernel** 产出带理由码的 **decision** 与可关联 **evidence**；拒绝把未定义对象交给模型「自行把握」。

（二）认知一致性失效与价值/本体锚定及防御性降级。 必要性：多轮对话与工具链可破坏用户与系统对「何物可信、何操作被允许」的隐含一致；压力下模型内生反思无契约保证。**设计含义：**将价值边界与本体约束写入外置 **policy**；在冲突信号下触发 **FailSafeObject** 所枚举的防御性降级（受控动作空间），而非继续全能力生成；恢复路径须写入权限与证据（第 4 章 R1/R2）。

（三）文本语义检索路径失效与表征异常及表示级监控。 必要性：仅监控表面 token 或短上下文不足以覆盖投毒、隐指令、跨文档拼接与检索排序操纵。**设计含义：**检索路径上强制血缘、分段、引用绑定；监控与证据须纳入表征异常与表示级（及行为轨迹级）信号，并与第 5 章评测用例及最小证据包字段对齐，使「当时看见了什么表征证据」可回放。

Definition 2.2 (解耦安全)**.** Decoupled Safety 指：安全约束在与任一具体模型内部参数相分离的专用控制层中表示、强制执行并接受审计的设计原则。**policy** 对外暴露稳定接口（事件类型、义务、决策与证据 schema），而不绑定于单一提供商 checkpoint 文件格式。

Invariant 2.3 (策略优先)**.** 若生成偏好与显式安全策略冲突，必须以策略层支配最终系统行为；部分结果（如改写或删节输出）仍须满足策略。

Invariant 2.4 (组合式黑盒接口)**.** **kernel** 消费类型化 **event**，产出 **decision** 与 **evidence**。下游模块不得在缺乏可审计升级路径的情况下绕过上述决策。

2.3 最小对象模型（与第 3–5 章接口）

主线：Decoupled Safety。下表为全书中须可版本、可引用、可测试的最小对象集合；证明与复杂形式化不进入正文，仅保留对象纪律。

对象	最小定义与邻章接口
`policy`（P）	版本化义务、阈值、允许动作空间；绑定租户/地域/工作流。第 4 章求值输入；第 5 章契约与回归锚。
`kernel`（K）	对 `event` 确定性求值，派发 `decision`，发射 `evidence`。第 3 章模块实例化。
`environment`（E）	拓扑、信任域、观测与算力预算、部署与观测分层。第 6 章前提与退化。
`evidence`（Ev）	可关联、可回放、可差分的记录集合。第 5 章最小证据包；第 6 章证据图谱边。
`event`	输入块、检索单元、工具调用、候选输出等类型化安全事件。第 4 章生命周期输入。
`decision`	allow / rewrite / sandbox / escalate / block / degrade 及理由码。第 4 章 FailSafe 触发输入。
`FailSafeObject`	触发条件、允许降级集合、服务不变量、恢复层级的绑定配置（非散文描述）。第 4 章协议正文；第 5 章 E1–E3。
`OOB_adaptation`	主推理链之外的观测—路由—适应闭环配置与证据锚（若采用）。第 5 章 RQ3 / E4–E6；可选附录细化。

接口句。第 3 章将 K 展开为可部署模块；第 4 章将 `FailSafeObject` 展开为服务协议；第 5 章将 `evidence` 与轨道纪律绑定到放行。

2.4 典型失效模式

Risk / Threat

归属模糊. 安全逻辑隐匿于提示词或模型权重中时，升级会在无回归检测的情况下静默改写有效策略。

Risk / Threat

编排绕检. 智能体与工作流通过备用工具或隐式信道绕开护栏；缺乏编排绑定强制时一致性崩溃。

Risk / Threat

证据缺失. 运营方无法复原为何作出某决策，审计、复盘与从事故中学习受阻。

2.5 有界主张与本书安全契约（bounded claim）

主线：Decoupled Safety。Decoupled Safety 在本书中的承诺是有界且可撤回的：在 `environment` 明示、`policy` 与检测器版本可查、观测与算力预算及 acceptance contract 签入的前提下，提高攻击者成本、限制失效半径，并在前提被破坏时退入第 4 章最低安全服务形态。**不承诺：**对任意自然语言与任意工具生态的全局可判定安全；不承诺模型永不产生事实错误——控制对象是策略义务与证据，不是真理表。口径与第 1 章阅读约定及第 6 章 claim discipline 严格同构。

Open Problem / Research Agenda

基础问题. 在异构模型、非确定解码与多步工具使用下，哪些组合式约束可在可度量误差界内被强制执行，且其证据包仍满足 Track A 放行纪律?

Key Takeaway

Decoupled Safety 是在计算—验证不对称与操纵现实下，唯一能把策略优先、实例级可验证 `decision`、`FailSafeObject` 与 `evidence` 压成同一可部署契约的系统原理；有界主张使该原理可与第 1 章总对象及第 6 章非目标并列辩护。

Chapter 3

参考架构与解耦安全内核

Chapter Objective

本章将总对象分解为可实现的层与模块，并把系统原理翼 Decoupled Safety 落到 Decoupled Safety Kernel 接口与交付表。**主线：** Unified AI Security Control Plane + Decoupled Safety。为第 4 章协议与第 5 章证据对象提供统一事件面。

Deliverables

- 从交互层到治理层的分层架构。
- 策略引擎、护栏、检索中介、工具控制、审计面等模块接口。
- 初始交付物与阶段归属（详见第 6 章）。

3.1 分层参考架构

主线： Unified AI Security Control Plane。架构按层划分职责：

- **交互层：** 用户与应用输入、认证与租户语境、会话管理、请求整形。
- **语境层：** 提示理解、路由、检索规划、血缘绑定、按敏感度与用途对语料分段。
- **模型执行层：** 模型路由、解码控制、事实锚定挂钩、在可用时的弃权与不确定性信号。
- **运行时强制层：** 策略引擎、护栏、检索中介、响应过滤、工具门控、确定性改写与删节、升级处置。
- **治理层：** 证据存储、评测流水线、发布闸、监控、事件回放、策略生命周期管理。

3.2 数据面、控制面与证据面

主线： Unified AI Security Control Plane。数据面承载提示、检索文本、嵌入元数据、工具请求与响应及补全。控制面承载策略、决策、义务、路由结果、风险评分与升级状态。证据面跨系统绑定标识符：策略版本、模型路由、检索语料切片、检测器版本、适当时的提示与文档哈希、决策与人工审批。保证论述依赖跨平面关联证据记录。

3.3 Decoupled Safety Kernel 接口

主线： Decoupled Safety。Decoupled Safety Kernel 暴露窄幅稳定接口以使强制可组合：

- **事件接入**。对输入、检索命中、候选补全、工具调用等进行规范化事件。
- **策略求值**。在定义事件上对版本化规则集与阈值做确定性求值。

- **动作派发**。允许、改写、约束、沙箱、升级、阻断、降级，并携带类型化参数。
- **证据发射**。输出可供 Evaluation Framework 与治理工具消费的结构化记录。

Module	Deliverable	Acceptance Criteria	Owner	Phase
策略引擎	模式 + 规则 + 决策轨迹	对约定事件类型可确定性回放	运行时策略	P1
输入/输出 Guardrails	分类器、校验器、改写模板	相对基线可测的绕过率下降	安全 ML	P1
检索安全服务	语料标注、引用绑定、检索白名单	注入/投毒实际危害下降	平台 + 应用	P1
工具控制器	能力矩阵、同意书、审批、沙箱	高风险动作须有显式策略路径	智能体平台	P2
审计面	仅追加日志、关联标识	可由证据完整复原事件	平台 SRE	P2
评测服务	套件、看板、回归	版本化包满足发布闸	质量保证	P1

Key Takeaway

Decoupled Safety Kernel 将 Decoupled Safety 落实为可实现接口：类型化事件、确定性决策与适于治理的证据。

Chapter 4

运行时强制与策略编排

Chapter Objective

本章将 Decoupled Safety 落实为可测运行时行为：风险闭环、策略生命周期、RAG/工具强制，并以两阶段 *Fail-Safe* 服务协议写清触发、降级空间、服务不变量、恢复层级与权限边界，供工程验收与第 5 章证据对象对齐。

Deliverables

- Measure–Profile–Select–Enforce–Evidence 与策略生命周期。
- RAG 与工具调用强制模式。
- Fail-Safe 协议：触发、降级、不变量、恢复与 authority boundary。

4.1 风险自适应控制闭环

主线： Unified AI Security Control Plane。在线强制与保证闭环对齐：

1. **测量（Measure）**。离线/在线测量产生决策信号（攻击成功率、漂移、拒绝质量、时延等）。
2. **画像（Profile）**。按模型与场景汇总风险暴露，给定部署语境。
3. **选择（Select）**。在风险、成本、时延与业务容忍度约束下选择控制深度（规则对轻量检测对重型检测；工具约束；检索分段）。
4. **强制（Enforce）**。经由 Decoupled Safety Kernel 接口确定性施加动作。
5. **证据与反馈**。发射审计记录；失效驱动基准更新、红队优先级与策略修订。

4.2 策略决策生命周期

主线： Decoupled Safety。单次请求维度：

1. 审视请求并提取风险信号（主题敏感度、信道信任、检索范围、工具暴露）。
2. 将请求绑定到适用的策略包与版本（租户、地理、负载类别）。
3. 评估干预：允许、改写、约束、沙箱、升级、阻断、降级，并给出显式理由码。
4. 记录决策及可回放的相关证据载荷。
5. 将事件与未遂注入离线套件与影子评测。

4.3 检索安全（RAG）

主线：Unified AI Security Control Plane。检索将第三方文本带入提示边界；应将检索片段视为不可信、类代码内容。控制包括：语料分段（公开与机密）、元数据与血缘要求、检索时过滤、与段落绑定的引用、矛盾处理、自敏感切片导出答案的最大特权范围、以及批量与在线投毒检测挂钩。检索策略须与包含投毒文档场景的评测协同演化。

4.4 工具调用控制

主线：Unified AI Security Control Plane。工具将语言映射为副作用；须按租户与工作流执行能力矩阵、参数类型校验、高影响动作的动态审批、可行时的沙箱执行、持久限速，以及只读与变更类工具的分离。编排器不得构造绕过已记录决策的平行路径。

4.5 两阶段 Fail-Safe 服务协议

主线：Decoupled Safety。本节将「升级、降级与人机协同」提升为可验收协议（企业可读表述；实现可映射至内部触发/动作编号）。**阶段一（检测与判定）**在 Decoupled Safety Kernel 内完成；**阶段二（服务降级与恢复）**在受控动作空间与明确权限边界内完成，且须产生与第 5 章最小证据包对齐的结构化记录。

4.5.1 触发接口（三类信号）

- **策略/规范冲突信号**——显式规则互斥、越权工具意图、或策略版本与运行态不一致。
- **社会技术/运营异常信号**——速率、来源、租户上下文突变，或人机审批队列积压超过 SLA。
- **验证器不确定/证据不足信号**——分类器低置信、检索血缘缺失、关键断言无法绑定证据等。

4.5.2 降级动作空间（受控四象）

在触发成立时，系统仅允许在下列预声明动作集合内迁移（具体映射由策略包配置）：**(D1)** 模板化拒绝或固定安全答复；**(D2)** 受限无状态沙箱内执行（禁用高副作用工具或缩小检索切片）；**(D3)** 对输出做安全删改或脱敏后返回；**(D4)** 硬终止当前请求并返回可解释错误码。每项须记录业务影响类别与必填证据字段，供发布闸与复盘引用。

4.5.3 服务不变量（示例 S1）

同步可用性契约：在降级路径下，同步 API 仍须在约定时限内返回可机器处理的响应（可为降级结果或明确错误）；不得无限阻塞主链路。降级不得静默破坏与租户约定的 SLA 语义（例如「必须返回理由码」）。恢复流程不得在未记录审批的情况下提升特权。

4.5.4 异构恢复层级

R1——规则化恢复：清除已知不良状态、回滚策略试验旗标、切换只读模式等自动化步骤。**R2——人工/规范性恢复：**法务、安全或数据治理签批后恢复全能力；须写入证据图谱并与策略版本绑定。**权限边界（authority boundary）**：何人/何服务可批准 R2、可修改何类策略字段，须在治理配置中单列，避免与运行时执行身份混同。

Evaluation / Assurance

运行时保证目标. 每条干预路径须配对指标：残余风险、效用影响、时延增量与审计完整性；Fail-Safe 须额外报告降级命中率、p95/p99 返回时延与错误码分布。

Key Takeaway

运行时强制与 Fail-Safe 协议将 Decoupled Safety 体现为真实事件上的可度量决策与可验收降级，而非与证据脱节的静态配置。

Chapter 5

评测框架：安全、效用与系统保证

Chapter Objective

本章为证据与治理引擎翼：以 RQ 组织评测问题与证据映射；定义契约与指标；规定多轨评测及 **Track A/B 纪律**；给出离线/影子/红队/回归/发布协议及最小可部署证据包，与第 4 章运行时对象及第 6 章放行闸对齐。

Deliverables

- RQ-first：评测问题与证据映射表。
- 契约、指标、多轨 + Track A/B 不混读纪律。
- 最小可部署证据包与发布/回归协议。

5.1 评测问题与证据映射（RQ-first）

主线：Evaluation Framework。先锁评测要回答的问题，再挂主表、机制证据与发布入口（避免「先有分再有故事」）：

- **RQ1（可部署联合目标）**——在既定 SLA 与成本下，安全—效用—时延的联合目标是否可稳定满足？证据：分层指标与线上影子对比。
- **RQ2（Fail-Safe 必要性）**——在对抗与社会技术压力下，协议化降级是否降低爆炸半径且不破坏服务不变量？证据：第 4 章触发—动作日志与回放。
- **RQ3（外置观测—路由—适应）**——带外闭环相对纯语义拦截的边际增益是否可复现？证据：对照实验与漂移监控。
- **RQ4（真实攻击面与发布）**——在代表性情境与法域轨约束下，残余风险是否低于 acceptance contract？证据：多轨聚合与签批制品。

5.2 语义、基准与验收契约

主线：Evaluation Framework。风险须在统一分类体系下关联检测类别、评分量表与义务。基准宪章（*benchmark constitution*）声明覆盖期望（须测量哪些失效类别及聚合方式）。验收契约（*acceptance contract*）将场景绑定阈值与例外，把测量转化为各部署阶段的准入条件。契约与策略包、检测器包联合版本化。

5.3 指标分层

主线：Evaluation Framework。在四个互补层次上评测：

- **安全**。攻击成功概率、绕过率、注入影响、不安全工具调用、渗出企图。
- **效用**。任务成功率、在有标注处的正确性、有用性代理、校准的拒绝行为、适用时的过度拒绝率。
- **系统**。时延开销、吞吐影响、内存与计算成本、负载下稳定性。
- **治理**。轨迹完整性、回放保真度、不可篡改校验、策略绑定正确性、事件下钻能力。

5.4 共享基础设施下的多轨评测

主线：Evaluation Framework。不同监管或组织义务不必坍缩为单一分数。可行模式是：共享执行主干（运行定义、目标、制品、结果存储、CI/CD 挂钩）配以在套件、聚合逻辑与报告模板上各异的多条评测轨，同时在发布决策上汇入统一决策面板。法域专属轨道（例如带本地化案例库的监管类别）宜作为一等公民，而非全球套件的薄翻译；证据包须显式引用轨道标识。

5.4.1 Track A 与 Track B 纪律（禁止混读）

制度规定：Track A（或等价命名）承载可部署结论——用于生产放行、对外合规陈述与客户合同指标；其聚合与阈值须与线上观测口径对齐。**Track B**（或等价命名）承载机制与组件上界压力测试——用于研发排序与架构改进，不得与 Track A 混成单一总分或单一「攻击成功率」叙事。**禁止行为：**将实验室上界结果直接写进生产放行摘要而不附迁移论证；将不同轨权重隐性合并。违反视为证据链断裂，发布闸应拒绝。

Evaluation Criteria

Capability	Security Metric	Utility Metric	System Metric	Evidence / Benchmark
输入/输出 Guardrails	绕过率、有害漏检	任务完成、用户摩擦	附加时延、尾延迟	红队提示、自适应攻击
检索控制	投毒命中率、未授权切片访问	答案正确性/有用性	检索时延、索引成本	投毒语料、注入文档
工具调用控制	不安全动作率、特权滥用	工作流成功率	审批时延	智能体攻击、工具链
多轨/区域套件	轨道专属通过阈值	可比的效用基线	运行成本、运营耗时	本地化套件 + 共享底座
审计/证据面	轨迹完整性、回放成功	根因定位耗时	存储、日志体量	事件回放演练、抽样审计

5.5 协议：离线、在线、回归与发布

主线：Evaluation Framework。**离线**套件驱动迭代与阻断缺陷；**影子**部署在可控风险下对比线上流量形态下的策略变体；**红队**探测自适应攻击模型；**回归**闸在策略、模型或检测器变更时对标准包施加单调改进类约束。发布标准组合统计阈值、最坏情形上限、必备证据制品与运维签批规则。

5.6 最小可部署证据包（Minimum Deployable Evidence Pack）

主线：Evaluation Framework。在资源受限时，下列证据为最低集合；缺任一项则不对生产主张升级或对外扩大承诺范围。

- **E1–E3（Fail-Safe 协议）**——代表性对抗与社会技术场景下，触发—降级—返回路径的正确性；降级路径 p95/p99 时延与成功返回率；恢复必要性（何种条件必须进入 R2）。
- **E4–E6（观测—路由—适应闭环，若适用）**——表征/行为异常监控相对基线的 tpr/fpr 与误报成本；带外路由相对纯语义拦截的边际增益；高密度可解释理由相对短提示对的效用—安全折中证据。
- **跨章关联**——每条证据须带策略版本、模型路由、检测器/规则包版本及（若适用）轨道标识（Track A/B），以便与第 6 章证据图谱边一致。

Open Problem / Research Agenda

评测前沿. 在非确定解码与策略干预下，组织如何在可度量置信区间约束下联合优化安全、效用、成本、时延与可审计性?

Key Takeaway

Evaluation Framework 将主观判断转化为证据：版本化套件、显式契约与可与 Unified AI Security Control Plane 一道经受审计与发布辩护的关联遥测。

Chapter 6

治理、部署与研究路线

Chapter Objective

本章闭合一主两翼：先声明主张口径与非目标、前提与退化态（claim discipline），再给出证据图谱与发布闸、组织运作模型、分阶段路线与交付表，使对外叙述成为「有边界的企业安全契约」而非能力清单。

Deliverables

- Claim discipline：非目标、有界保证、前提与退化 regime。
- 证据图谱、发布闸与分阶段交付物。
- 运作模型与研究路线（含四能力单元与统一 program，附录可扩）。

6.1 主张口径与非目标（Claim discipline）

主线：综合。**本书主张：**在明示前提与可观测预算下，Unified AI Security Control Plane 结合 Decoupled Safety 与 Evaluation Framework 提供可部署、可测量、可撤回的风险控制与证据链。**本书不主张（Non-goals）：**（i）对任意自然语言任务与任意工具生态的全局可判定安全；（ii）将单次离线评测或单一攻击成功率等同于生产安全；（iii）将 Track B 上界结果不经迁移论证写入对外「可部署结论」；（iv）保证模型永不产生事实错误——本书控制的是策略义务与证据，而非一般真理。

6.2 前提条件与退化态（Preconditions & degradation regimes）

主线：综合。保证陈述依赖分层前提；前提失效时系统须退入已声明的最低形态（与第 4 章 Fail-Safe 及第 5 章最小证据包一致）。

- **理论/语义前提**——风险分类、策略 schema 与事件类型在版本 P 内可判定；不可判定部分通过验收契约显式列为残余风险。
- **部署/观测前提**——关键遥测、日志不可篡改与关联 ID 可用；若观测降级，则同时收紧可对外主张的能力包（例如禁用高风险工具）。
- **治理前提**——R2 审批链、法务与数据主体权利流程可用；若不可用，则禁止依赖人工恢复的全能力路径。
- **观测能力分层**——在白盒、半白盒、黑盒不同观测度下，可主张的保证强度不同；须在对外材料中分层披露，不得混称为同一「安全等级」。

6.3 证据图谱与发布治理

主线： Evaluation Framework / Unified AI Security Control Plane。发布决策依赖连接基准运行、策略版本、模型路由、检测器版本、代表性遥测切片与人工审批的证据图谱。图谱须支持差分更新：仅子系统变更时的部分重跑。治理通过显式验收契约整合法务、隐私与安全相关方，而非仅依赖临时会议。

6.4 组织运作模型

主线： 综合。高效项目持续对齐四类能力：（i）安全科学与基准治理；（ii）运行时 Decoupled Safety Kernel 工程；（iii）证据、CI/CD 与发布闸；（iv）多语与地域化智能——作为语义测试与检测器的源头，而非事后补丁。目标是理论、系统、基准与运营的共同演化，而非孤立团队优化局部指标。

6.5 分阶段部署路线

- **第一阶段——基线包络**。输入/输出 Guardrails、结构化审计日志、面向最高风险场景的极简验收契约与回归套件。
- **第二阶段——语境风险**。检索中介、工具策略、扩展的证据关联、影子评测。
- **第三阶段——统一控制面**。跨模型策略抽象、中心化策略生命周期、决策与证据的一体化看板。
- **第四阶段——自适应保证**。具形式目标的风险自适应选择、回归发现自动化加强、在可行处的定向验证实验。

Module	Deliverable	Acceptance Criteria	Owner	Phase
基准宪章	成文档的套件与聚合规则	CI 闸通过且具签名制品	质量保证负责人	P1
验收契约	场景阈值与例外	发布委员会使用版本化包	风险 + 产品	P1
安全内核 MVP	事件类型 + 强制 + 日志	相对基线可测的绕过率下降	运行时团队	P1
检索与工具策略	生产环境中介规则	相对红队目录事件下降	平台	P2
证据服务	关联标识、不可篡改	在时间预算内完成事件回放	SRE	P2

6.6 研究路线

主线： 综合。优先主题包括：异构栈上的组合式安全；带后悔界权衡的运行时可控性；经验证接口上的策略—模型分离；借助统计与贝叶斯检验的非确定评测；安全—效用—时延多目标优化；以及在可行处将基准与形式主张相连的保证科学。

Key Takeaway

成熟项目同时交付控制、证据与学习：工程化强制、诚实测量，并通过可复现事故与基准叠加组织能力。

Chapter A

地域化与多语言评测

法域义务与语言引入与全球单一分数不可通约的风险语义。可行模式包括：带法域标签的本地化套件库；共享执行基础设施但类别、聚合与报告模板相异的并行轨道；语言感知检测器与分词陷阱；混合语言输入；以及从监管类别到测试义务的显式映射。证据包须标明轨道、套件版本及纳入统一发布决策板的理由。地域/多语轨道的对外结论须遵守第 5 章 **Track A/B 纪律**：仅当该轨被显式纳入 Track A 契约时才可作为可部署放行依据，否则默认归入 Track B 或等效压力轨。

Chapter B

术语与角色边界

安全判断提供方负责策略解释、风险评分、检测制品、可解释性载荷及适于审计的结构化证据。**执行平台**提供网络、扩缩容、编排 SLA 与负载管理。边界清晰可避免「任一侧均无法产出可回放轨迹」的归属真空。对外沟通时，内部项目命名宜映射至上述中性角色。